

Các công cụ hỗ trợ — việc khai thác —

Johnathan Hữu Trí
nhtri2003@gmail.com

Bắt đầu
nào!

Nội dung bài học!

(Click vào tiêu đề cho nhanh)

1. GDB

Debug binary và những
tiện ích bổ sung

2. Pwntools

Framework của python

3. IDA

Dịch ngược chương
trình

4. checksec

Kiểm tra các chức năng
bảo vệ của file



Nội dung bài học!

(Click vào tiêu đề cho nhanh)

5. ropper

Tìm kiếm những đoạn nhỏ của chương trình

6. pwninit

Patch libc vào binary

7. file

Kiểm tra định dạng của file

8. man page

Tìm kiếm cách sử dụng các thư viện trong c



A graphic of a spiral-bound notebook with a white page, a red cover, and a green background. The page has a spiral binding at the top. On the left side, there are two horizontal tabs, one yellow and one orange. In the center of the page, the number '01' is displayed in a large, bold, black font, surrounded by a light green circular arrow. Below the number, the text 'GDB' is written in a bold, red font. At the bottom, the text 'Debug binary và những tiện ích bổ sung' is written in a black font.

01

GDB

Debug binary và những
tiện ích bổ sung

Hướng dẫn cài đặt

Chạy câu lệnh sau và nhập password để cài gdb lên máy:

```
sudo apt-get install  
libc6-dbg gdb valgrind
```

Sau đó gõ "gdb" để kiểm tra xem chương trình đã được cài hay chưa

```
user2@ubuntu:~$ sudo apt-get install libc6-dbg gdb valgrind  
[sudo] password for user2:  
Reading package lists... Done  
Building dependency tree  
Reading state information... Done  
gdb is already the newest version (9.2-0ubuntu1-20.04.1).  
gdb set to manually installed.  
libc6-dbg is already the newest version (2.31-0ubuntu9.9).  
libc6-dbg set to manually installed.  
Suggested packages:  
  valgrind-dbg valgrind-mpi kcachegrind alleyoop valkyrie  
The following NEW packages will be installed:  
  valgrind  
0 upgraded, 1 newly installed, 0 to remove and 78 not upgraded.  
Need to get 20.3 MB of archives.  
After this operation, 90.0 MB of additional disk space will be used.  
Do you want to continue? [Y/n]  
Get:1 http://us.archive.ubuntu.com/ubuntu focal-updates/main amd64 valgrind amd64 3.15.0-1ubuntu9.1 [20.3 MB]  
77% [1 valgrind 19.6 MB/20.3 MB 96%] 53.2  
kB/s 13s^Fetched 20.3 MB in 5min 3s (67.0 kB/s)  
  
Selecting previously unselected package valgrind.  
(Reading database ... 156995 files and directories currently installed.)  
Preparing to unpack .../valgrind_3.15.0-1ubuntu9.1_amd64.deb ...  
Unpacking valgrind (3.15.0-1ubuntu9.1) ...  
Setting up valgrind (3.15.0-1ubuntu9.1) ...  
Processing triggers for man-db (2.9.1-1) ...
```



```
user2@ubuntu:~$ gdb  
GNU gdb (Ubuntu 9.2-0ubuntu1-20.04.1) 9.2  
Copyright (C) 2020 Free Software Foundation, Inc.  
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>  
This is free software: you are free to change and redistribute it.  
There is NO WARRANTY, to the extent permitted by law.  
Type "show copying" and "show warranty" for details.  
This GDB was configured as "x86_64-linux-gnu".  
Type "show configuration" for configuration details.  
For bug reporting instructions, please see:  
<http://www.gnu.org/software/gdb/bugs/>.  
Find the GDB manual and other documentation resources online at:  
  <http://www.gnu.org/software/gdb/documentation/>.  
  
For help, type "help".  
Type "apropos word" to search for commands related to "word".  
(gdb) █
```



GEF

GEF (GDB Enhanced Features) là các tính năng bổ sung cho GDB giúp hỗ trợ việc khai thác.

Một vài tính năng đặc trưng như là hiển thị sẵn các thanh ghi, các instructions cho mình và hỗ trợ tìm kiếm chuỗi hoặc địa chỉ.

Hướng dẫn cài đặt

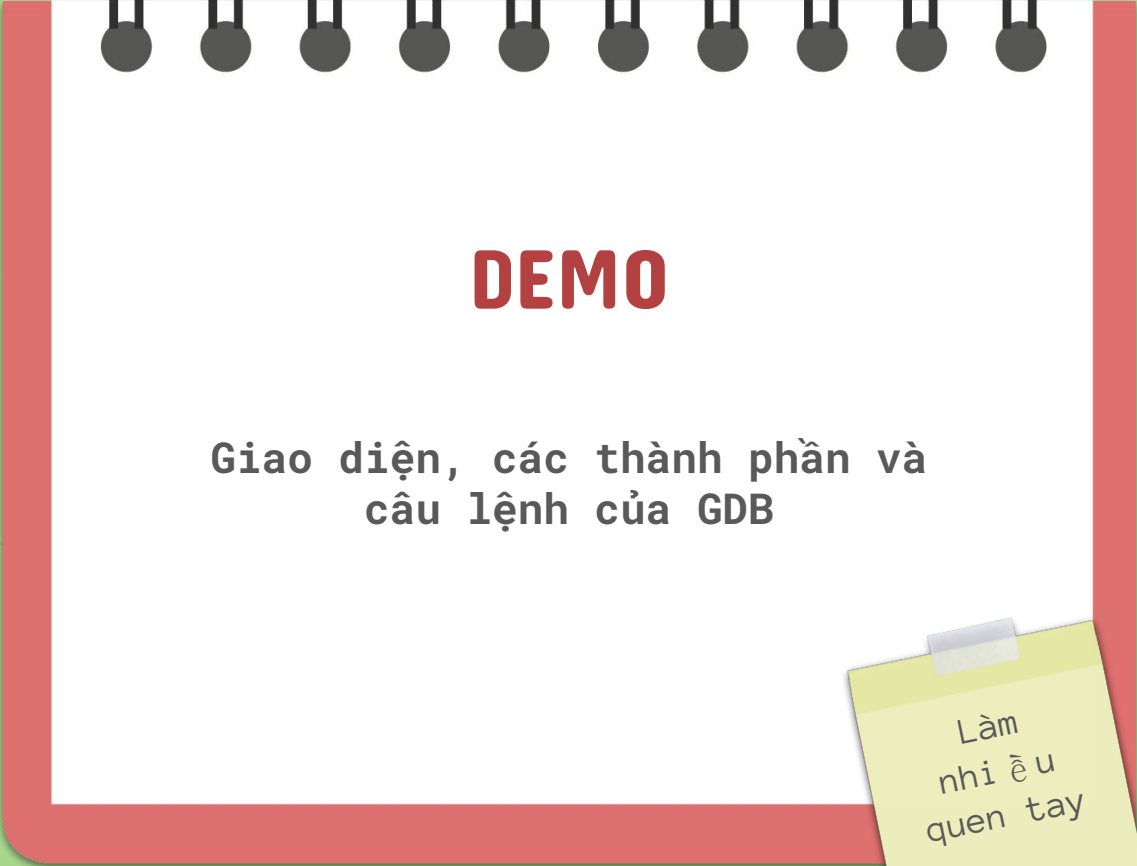
```
user2@ubuntu:~$ bash -c "$(curl -fsSL https://gef.blah.cat/sh)"
```

Để cài GEF, ta chạy câu lệnh sau:

```
bash -c "$(curl -fsSL https://gef.blah.cat/sh)"
```

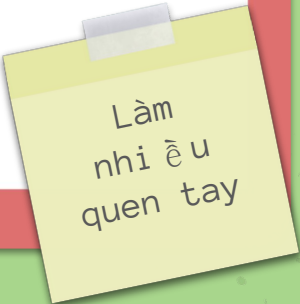
Sau đó gõ “gdb” để kiểm tra xem GEF đã được cài hay chưa





DEMO

Giao diện, các thành phần và
câu lệnh của GDB



Làm
nhiều
quen tay

[Legend: Modified register Code Heap Stack String]					registers
<pre> \$rax : 0x00555555555129 → <main+0> endbr64 \$rbx : 0x00555555555140 → <__libc_csu_init+0> endbr64 \$rcx : 0x00555555555140 → <__libc_csu_init+0> endbr64 \$rdx : 0x007fffffff1c8 → 0x007fffffff43e → "SHELL=/bin/bash" \$rsp : 0x007fffffff0c8 → 0x007ffff7de9083 → <__libc_start_main+243> mov edi, eax \$rbp : 0x0 \$rsi : 0x007fffffff1b8 → 0x007fffffff41a → "/home/johnathanhuutri/Codes/cau12/r" \$rdi : 0x1 \$rip : 0x00555555555129 → <main+0> endbr64 \$r8 : 0x0 \$r9 : 0x007ffff7fe0d60 → <_dl_fini+0> endbr64 \$r10 : 0xf \$r11 : 0x2 \$r12 : 0x00555555555040 → <_start+0> endbr64 \$r13 : 0x007fffffff1b0 → 0x0000000000000001 \$r14 : 0x0 \$r15 : 0x0 \$eflags: [ZERO carry PARITY adjust sign trap INTERRUPT direction overflow resume virtualx86 identification] \$cs: 0x33 \$ss: 0x2b \$ds: 0x00 \$es: 0x00 \$fs: 0x00 \$gs: 0x00 </pre>					
<pre> 0x007fffffff0c8 +0x0000: 0x007ffff7de9083 → <__libc_start_main+243> mov edi, eax ← \$rsp 0x007fffffff0d0 +0x0008: 0x007ffff7ffc620 → 0x00050a1000000000 0x007fffffff0d8 +0x0010: 0x007fffffff1b8 → 0x007fffffff41a → "/home/johnathanhuutri/Codes/cau12/r" 0x007fffffff0e0 +0x0018: 0x000000001000000000 0x007fffffff0e8 +0x0020: 0x00555555555129 → <main+0> endbr64 0x007fffffff0f0 +0x0028: 0x00555555555140 → <__libc_csu_init+0> endbr64 0x007fffffff0f8 +0x0030: 0x9f1047d9e3ad1435 0x007fffffff100 +0x0038: 0x00555555555040 → <_start+0> endbr64 </pre>					stack
<pre> 0x555555555119 <__do_global_ctors_aux+57> nop DWORD PTR [rax+0x0] 0x555555555120 <frame_dummy+0> endbr64 0x555555555124 <frame_dummy+4> jmp 0x5555555550a0 <register_tm_clones> → 0x555555555129 <main+0> endbr64 0x55555555512d <main+4> push rbp 0x55555555512e <main+5> mov rbp, rsp 0x555555555131 <main+8> mov eax, 0x0 0x555555555136 <main+13> pop rbp 0x555555555137 <main+14> ret </pre>					code:x86:64
<pre> [#0] Id 1, Name: "r", stopped 0x555555555129 in main (), reason: TEMPORARY BREAKPOINT </pre>					threads
<pre> [#0] 0x555555555129 → main() </pre>					trace
gef>					

code:x86:64

```
0x5555555553c4 <main+152>      mov     esi, eax
0x5555555553c6 <main+154>      lea     rdi, [rip+0xc37]      # 0x5555555556004
0x5555555553cd <main+161>      mov     eax, 0x0
→ 0x5555555553d2 <main+166>      call    0x555555555090 <printf@plt>
↳ 0x555555555090 <printf@plt+0>  endbr64
0x555555555094 <printf@plt+4>      bnd     jmp QWORD PTR [rip+0x2f35]      # 0x5555555557fd0 <printf@got.plt>
0x55555555509b <printf@plt+11>     nop     DWORD PTR [rax+rax*1+0x0]
0x5555555550a0 <_start+0>          endbr64
0x5555555550a4 <_start+4>          xor     ebp, ebp
0x5555555550a6 <_start+6>          mov     r9, rdx
```

arguments (guessed)

```
printf@plt (
    $rdi = 0x0055555556004 → 0x00000000207525 ("%u "?),
    $rsi = 0x0000000000000001,
    $rdx = 0x000000000000000a,
    $rcx = 0x000000000000000a
)
```

④ Tự động đoán các
tham số khi thực thi hàm

```
r r.c
(pyppwndbg) johnathanhuutri@JohnathanHuuTri:~/Codes/caul2$ gdb r
GNU gdb (Ubuntu 9.2-0ubuntu1~20.04.1) 9.2
Copyright (C) 2020 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<http://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
<http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word"...
GEF for linux ready, type 'gef' to start, 'gef_config' to configure
90 commands loaded and 5 functions added for GDB 9.2 in 0.00ms using Python engine
3.8
Reading symbols from r...
(No debugging symbols found in r)
gef> |
```

```
(pyppwndbg) johnathanhuutri@JohnathanHuuTri:~/Codes/caul2$ gdb
GNU gdb (Ubuntu 9.2-0ubuntu1~20.04.1) 9.2
Copyright (C) 2020 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<http://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
<http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word"...
GEF for linux ready, type 'gef' to start, 'gef_config' to configure
90 commands loaded and 5 functions added for GDB 9.2 in 0.00ms using Python engine
3.8
gef> file r
Reading symbols from r...
(No debugging symbols found in r)
gef> |
```

Các câu lệnh cơ bản

Để debug 1 file, gõ:

`gdb <tên file>`

Hoặc gõ gdb trước rồi gõ

`file <tên file>`

```
gef> file r
Reading symbols from r...
(No debugging symbols found in r)
gef> start
[*] Breaking at '0x132c'
[*] Failed to find objfile or not a valid file format: [Errno 2] No such file or di
rectory: 'system-supplied DSO at 0x7ffff7fce000'
[ Legend: Modified register | Code | Heap | Stack | String ]

registers
$rax : 0x0055555555532c → <main+0> endbr64
$rbx : 0x00555555555410 → <_libc_csu_init+0> endbr64
$rcx : 0x00555555555410 → <_libc_csu_init+0> endbr64
$rdx : 0x007fffffffe1c8 → 0x007fffffffe43f → "SHELL=/bin/bash"
$rspx : 0x007fffffffe0c8 → 0x007ffff7de9083 → <_libc_start_main+243> mov edi,
eax
$rbp : 0x0
$rsi : 0x007fffffffe1b8 → 0x007fffffffe41b → "/home/johnathanhuutri/Codes/cau
12/r"
$rdi : 0x1
$rip : 0x0055555555532c → <main+0> endbr64
$r8 : 0x0
$r9 : 0x007ffff7fe0d60 → <_dl_fini+0> endbr64
$r10 : 0xf
$r11 : 0x2
$r12 : 0x0055555555550a0 → <_start+0> endbr64
$r13 : 0x007fffffffe1b0 → 0x0000000000000001
$r14 : 0x0
$r15 : 0x0
$eflags: [ZERO carry PARITY adjust sign trap INTERRUPT direction overflow resume vi
rtualx86 identification]
$cs: 0x33 $ss: 0x2b $ds: 0x00 $es: 0x00 $fs: 0x00 $gs: 0x00
```

Các câu lệnh cơ bản

Để chạy từ đầu chương trình, nhập:

start

Để chạy chương trình bình thường, nhập:

run

```
gef> file r
Reading symbols from r...
(No debugging symbols found in r)
gef> run
Starting program: /home/johnathanhuutri/Codes/cau12/r
[*] Failed to find objfile or not a valid file format: [Errno 2] No such file or di
rectory: 'system-supplied DSO at 0x7ffff7fce000'
1 2 2 3 4 4 5 7 9 9 123
[Inferior 1 (process 10339) exited normally]
gef> |
```

Các câu lệnh cơ bản

Để chạy từ đầu chương trình và truyền tham số:

start <arg1> <arg2> ...

Để chạy chương trình bình thường với tham số, nhập:

run <arg1> <arg2> ...

```
gef> run 4321 1234
Starting program: /home/johnathanhuutri/Codes/caul2/r 4321 1234
[*] Failed to find objfile or not a valid file format: [Errno 2] No such file or directory: 'system-supplied DSO at 0x7ffff7fce000'
1 2 2 3 4 4 5 7 9 9 123
[Inferior 1 (process 10346) exited normally]
gef> |
```

```
gef> start abc 1234
[+] Breaking at '0x5555555532c'
[*] Failed to find objfile or not a valid file format: [Errno 2] No such file or directory: 'system-supplied DSO at 0x7ffff7fce000'
[ Legend: Modified register | Code | Heap | Stack | String ]

registers
$rax : 0x005555555532c → <main+0> endbr64
$rbx : 0x00555555555410 → <__libc_csu_init+0> endbr64
$rcx : 0x00555555555410 → <__libc_csu_init+0> endbr64
$rdx : 0x007fffffffe1c8 → 0x007fffffffe43f → "SHELL=/bin/bash"
$rsp : 0x007fffffffe0b8 → 0x007ffff7de9083 → <__libc_start_main+243> mov edi,
eax
$rbp : 0x0
$rsi : 0x007fffffffe1a8 → 0x007fffffffe412 → "/home/johnathanhuutri/Codes/cau
```

Các câu lệnh cơ bản

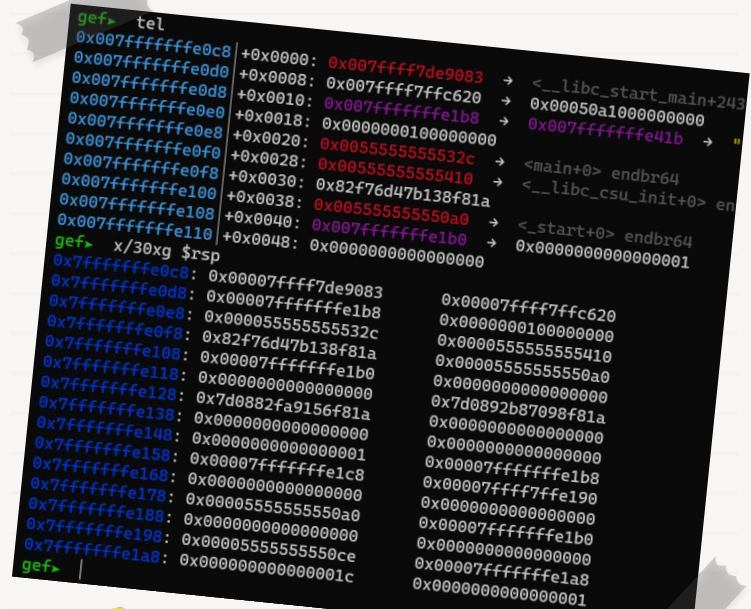
Stack là thanh ghi quan trọng.
Để kiểm tra stack, nhập

tel

Hoặc nhập:

x/<số>yg \$rsp

Với <số> là số lượng địa chỉ
8 byte (ký tự g) mình muốn
xem dưới dạng hex (ký tự x)



```
gef> tel
0x007fffffe0c8: +0x0000: 0x007ffff7de9083 → <_libc_start_main+243
0x007fffffe0d0: +0x0008: 0x007ffff7ffc620 → 0x00050a1000000000
0x007fffffe0d8: +0x0010: 0x007fffffe1b8 → 0x007fffffe41b → "
0x007fffffe0e0: +0x0018: 0x0000000100000000
0x007fffffe0e8: +0x0020: 0x0055555555532c → <main+0> endbr64
0x007fffffe0f0: +0x0028: 0x00555555555410 → <_libc_csu_init+0> en
0x007fffffe0f8: +0x0030: 0x82f76d47b138f81a
0x007fffffe100: +0x0038: 0x005555555550a0 → <.start+0> endbr64
0x007fffffe108: +0x0040: 0x007fffffe1b0 → 0x0000000000000001
0x007fffffe110: +0x0048: 0x0000000000000000
gef> x/30yg $rsp
0x7fffffe0c8: 0x00007ffff7de9083
0x7fffffe0d0: 0x00007fffffe1b8
0x7fffffe0e8: 0x000055555555532c
0x7fffffe0f8: 0x82f76d47b138f81a
0x7fffffe108: 0x00007fffffe1b0
0x7fffffe118: 0x0000000000000000
0x7fffffe128: 0x7d0882fa9156f81a
0x7fffffe138: 0x0000000000000000
0x7fffffe140: 0x0000000000000000
0x7fffffe150: 0x00007fffffe1c8
0x7fffffe160: 0x0000000000000000
0x7fffffe178: 0x00005555555550a0
0x7fffffe188: 0x0000000000000000
0x7fffffe198: 0x00005555555550ce
0x7fffffe1a8: 0x0000000000000001c
0x00007ffff7ffc620
0x0000000100000000
0x0000555555555410
0x00005555555550a0
0x0000000000000000
0x7d0892b87098f81a
0x0000000000000000
0x0000000000000000
0x00007fffffe1b8
0x00007ffff7ffe190
0x0000000000000000
0x00007fffffe1b0
0x0000000000000000
0x00007fffffe1a8
0x0000000000000001
```

Các câu lệnh cơ bản

Một vài cách khác để xem dữ liệu:

x/<số>s <địa chỉ/thanh ghi>
x/<số>b <địa chỉ/thanh ghi>
x/<số>xw <địa chỉ/thanh ghi>

```
gef> x/2xg $rsp
0x7fffffff7de9083 0x00007ffff7ffc620
0x7fffffff7de9083 0x00007ffff7ffc620
gef> x/8b 0x7fffffff7de9083
0x7fffffff7de9083: 0x83 0x90 0xde 0xf7 0xff 0x00 0x00 0x00
gef> x/4xw 0x7fffffff7de9083
0x7fffffff7de9083: 0xf7de9083 0x00007fff 0xf7ffc620 0x00007fff
gef> x/s 0x00007fffffff7de9083
0x7fffffff7de9083: "/home/johnathanhuutri/Codes/caul2/r"
```

Để tìm kiếm dữ liệu, ta có thể dùng lệnh search-pattern (chỉ có ở GEF):

search-pattern <chuỗi/địa chỉ>

```
gef> search-pattern /bin/sh
[+] Searching '/bin/sh' in memory
[+] In '/usr/lib/x86_64-linux-gnu/libc-2.31.so' (0x7ffff7f5f000-0x7ffff7fad000)
0x7ffff7f795bd - 0x7ffff7f795c4 → "/bin/sh"
```

```
gef> x/2xg $rsp
0x7fffffff7de9083 0x00007ffff7ffc620
gef> search-pattern 0x00007ffff7de9083
[+] Searching '\x83\x90\xde\xf7\xff\x00\x00' in memory
[+] In '[stack]' (0x7ffff7f5f000-0x7ffff7fff000), permission=rw-
0x7fffffff7de9083 - 0x7fffffff7de9083 → "\x83\x90\xde\xf7\xff\x00\x00"
```

Các câu lệnh cơ bản

Để nhảy sang
lệnh kế tiếp,
nhập:

ni

```
➔ 0x555555553cd <main+161>      mov     eax, 0x0
• 0x555555553d2 <main+166>      call    0x555555555090 <printf@plt>
0x555555553d7 <main+171>      add     DWORD PTR [rbp-0x48], 0x1
```

```
gef> ni|
```

```
➔ 0x555555553d2 <main+166>      call    0x555555555090 <printf@plt>
↳ 0x555555555090 <printf@plt+0>  endbr64
0x555555555094 <printf@plt+4>    bnd     jmp QWORD PTR [rip+0x2f35]
555555557fd0 <printf@got.plt>
0x55555555509b <printf@plt+11>  nop     DWORD PTR [rax+rax*1+0x0]
```

```
gef> ni|
```

```
• 0x555555553d2 <main+166>      call    0x555555555090 <printf@plt>
➔ 0x555555553d7 <main+171>      add     DWORD PTR [rbp-0x48], 0x1
0x555555553db <main+175>      mov     eax, DWORD PTR [rbp-0x48]
```

Các câu lệnh cơ bản

Để nhảy vào
một hàm, nhập:

si

```
➔ 0x555555553cd <main+161>      mov     eax, 0x0
• 0x555555553d2 <main+166>      call    0x555555555090 <printf@plt>
0x555555553d7 <main+171>      add     DWORD PTR [rbp-0x48], 0x1
```

gef> ni|

```
➔ 0x555555553d2 <main+166>      call    0x555555555090 <printf@plt>
↳ 0x555555555090 <printf@plt+0>  endbr64
0x555555555094 <printf@plt+4>  bnd     jmp QWORD PTR [rip+0x2f35]
555555557fd0 <printf@got.plt>
0x55555555509b <printf@plt+11> nop     DWORD PTR [rax+rax*1+0x0]
```

gef> si|

```
0x55555555508b <__stack_chk_fail@plt+11> nop     DWORD PTR [rax+rax*1+0x0]
➔ 0x555555555090 <printf@plt+0>  endbr64
0x555555555094 <printf@plt+4>  bnd     jmp QWORD PTR [rip+0x2f35]          # 0x555
5555557fd0 <printf@got.plt>
```

Các câu lệnh cơ bản

Để tiếp tục
thực thi chương
trình, nhập:

c

```
code:x86:64
0x55555555329 <quick_sort+99> nop
0x5555555532a <quick_sort+100> leave
0x5555555532b <quick_sort+101> ret
→ 0x5555555532c <main+0>      endbr64
0x55555555330 <main+4>        push    rbp
0x55555555331 <main+5>        mov     rbp, rsp
0x55555555334 <main+8>        sub     rsp, 0x50
0x55555555338 <main+12>       mov     rax, QWORD PTR fs:0x28
0x55555555341 <main+21>       mov     QWORD PTR [rbp-0x8], rax

threads
[#0] Id 1, Name: "r", stopped 0x5555555532c in main (), reason: BREAKPOINT
trace
[#0] 0x5555555532c → main()

gef> c
Continuing.
1 2 2 3 4 4 5 7 9 9 123
[Inferior 1 (process 116) exited normally]
gef> |
```

Các câu lệnh cơ bản

Để liệt kê địa chỉ của các file được load cũng như xem quyền truy cập của từng vùng, nhập:

`vmmmap`

Để giới hạn lại thành địa chỉ của 1 file cụ thể, nhập:

`vmmmap <tên file>`

```
gef> vmmmap
[ Legend: Code | Heap | Stack ]
Start      End      Offset    Perm Path
0x005555540000 0x005555540100 0x000000000000 r-x /home/johnathanhuutri/ez-pwn-1
0x0055555560000 0x00555555601000 0x000000000000 r-- /home/johnathanhuutri/ez-pwn-1
0x00555555601000 0x00555555602000 0x00000000001000 rw- /home/johnathanhuutri/ez-pwn-1
0x007ffff7dc5000 0x007ffff7de7000 0x00000000000000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7de7000 0x007ffff7f5f000 0x00000000022000 r-x /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7f5f000 0x007ffff7fad000 0x00000000019a000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fad000 0x007ffff7fb1000 0x0000000001e7000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fb1000 0x007ffff7fb3000 0x0000000001eb000 rw- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fb3000 0x007ffff7fb9000 0x00000000000000 rw- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fca000 0x007ffff7fce000 0x00000000000000 r-- [vvar]
0x007ffff7fce000 0x007ffff7fcf000 0x00000000000000 r-x [vdso]
0x007ffff7fcf000 0x007ffff7fd0000 0x00000000000000 r-- /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7fd0000 0x007ffff7fd0000 0x00000000000000 r-x [vdso]
0x007ffff7fd0000 0x007ffff7fd3000 0x000000000001000 r-x /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7fd3000 0x007ffff7ffb000 0x000000000024000 r-- /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7ffb000 0x007ffff7ffd000 0x00000000002c000 r-- /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7ffd000 0x007ffff7ffe000 0x00000000002d000 rw- /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7ffe000 0x007ffff7fff000 0x00000000000000 rw- /usr/lib/x86_64-linux-gnu/ld-2.31.so
0x007ffff7fff000 0x007ffff7fff000 0x00000000000000 rw- [stack]
gef> |
```

```
gef> vmmmap ez
[ Legend: Code | Heap | Stack ]
Start      End      Offset    Perm Path
0x0055555400000 0x0055555401000 0x00000000000000 r-x /home/johnathanhuutri/ez-pwn-1
0x0055555560000 0x00555555601000 0x00000000000000 r-- /home/johnathanhuutri/ez-pwn-1
0x00555555601000 0x00555555602000 0x00000000001000 rw- /home/johnathanhuutri/ez-pwn-1
gef> |
```

```
gef> vmmmap libc
[ Legend: Code | Heap | Stack ]
Start      End      Offset    Perm Path
0x007ffff7dc5000 0x007ffff7de7000 0x00000000000000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7de7000 0x007ffff7f5f000 0x00000000022000 r-x /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7f5f000 0x007ffff7fad000 0x00000000019a000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fad000 0x007ffff7fb1000 0x0000000001e7000 r-- /usr/lib/x86_64-linux-gnu/libc-2.31.so
0x007ffff7fb1000 0x007ffff7fb3000 0x0000000001eb000 rw- /usr/lib/x86_64-linux-gnu/libc-2.31.so
gef> |
```

Các câu lệnh cơ bản

Để tìm địa chỉ saved rbp và saved rip, nhập:

info frame

```
gef> info frame
Stack level 0, frame at 0x7fffffff120:
rip = 0x555554007ce in main; saved rip = 0x7ffff7de9083
Arglist at 0x7fffffff110, args:
Locals at 0x7fffffff110, Previous frame's sp is 0x7fffffff120
Saved registers:
  rbp at 0x7fffffff110, rip at 0x7fffffff118
gef> |
```

Vậy địa chỉ saved rbp được lưu tại địa chỉ stack 0x7fffffff110 và địa chỉ saved rip được lưu tại địa chỉ stack là 0x7fffffff118

```
gef> x/2xg 0x7fffffff110
0x7fffffff110: 0x0000000000000000 0x00007ffff7de9083
gef> |
```

saved rbp *saved rip*

Các câu lệnh cơ bản

Để xem lại dữ liệu trên các thanh ghi, gõ:

info registers



```
gef> info registers
rax      0x5555554007ca    0x55555554007ca
rbx      0x555555400870    0x5555555400870
rcx      0x555555400870    0x5555555400870
rdx      0x7fffffff218     0x7fffffff218
rsi      0x7fffffff208     0x7fffffff208
rdi      0x1               0x1
rbp      0x7fffffff110     0x7fffffff110
rsp      0x7fffffff110     0x7fffffff110
r8        0x0               0x0
r9        0x7ffff7fe0d60    0x7ffff7fe0d60
r10       0xf               0xf
r11       0x2               0x2
r12       0x5555554006c0    0x55555554006c0
r13       0x7fffffff200     0x7fffffff200
r14       0x0               0x0
r15       0x0               0x0
rip       0x5555554007ce    0x55555554007ce <main+4>
eflags    0x246             [ PF ZF IF ]
cs        0x33              0x33
ss        0x2b              0x2b
ds        0x0               0x0
es        0x0               0x0
fs        0x0               0x0
gs        0x0               0x0
k0        0x0               0x0
k1        0x0               0x0
k2        0x0               0x0
k3        0x0               0x0
k4        0x0               0x0
k5        0x0               0x0
k6        0x0               0x0
k7        0x0               0x0
gef> |
```

**“Đặt breakpoint để debug cho dễ.
Đặt breakpoint tại những nơi dữ
liệu bị thay đổi”**

Johnathan Hữu Trí

Các câu lệnh cơ bản

Để đặt breakpoint
theo tên hàm, nhập:

b <tên hàm>

b*<tên hàm>+<số>

Để đặt breakpoint tại
1 địa chỉ cụ thể:

b*<địa chỉ>

```
0x55555555329 <quick_sort+99> nop
0x5555555532a <quick_sort+100> leave
0x5555555532b <quick_sort+101> ret
→ 0x5555555532c <main+0> endbr64
0x55555555330 <main+4> push rbp
0x55555555331 <main+5> mov rbp, rsp
0x55555555334 <main+8> sub rsp, 0x50
0x55555555338 <main+12> mov rax, QWORD PTR fs:0x28
0x55555555341 <main+21> mov QWORD PTR [rbp-0x8], rax
```

[#0] Id 1, Name: "r", stopped 0x5555555532c in main (), reason: BP

[#0] 0x5555555532c → main()

```
gef> b main
Breakpoint 1 at 0x5555555532c
gef> b*main+4
Breakpoint 2 at 0x55555555330
gef> b*0x55555555331
Breakpoint 3 at 0x55555555331
gef> |
```

Các câu lệnh bổ sung

Tạo chuỗi pattern để tìm khoảng cách:

Pattern create <số byte>

Tìm khoảng cách (offset) bằng pattern:

pattern search <thanh ghi>

pattern search <địa chỉ>

```
gef> pattern create 0x20
[+] Generating a pattern of 32 bytes (n=8)
aaaaaaaabaaaaaaacaaaaaadaaaaaaa
[+] Saved as '$_gef2'
```

Nhập pattern đó vào

```
0x007fffffe0b0 | +0x0000: "aaaaaaaabaaaaaaacaaaaaadaaaaaaa"
0x007fffffe0b8 | +0x0008: "baaaaaaacaaaaaadaaaaaaa"
0x007fffffe0c0 | +0x0010: "caaaaaaadaaaaaaa"
0x007fffffe0c8 | +0x0018: "daaaaaa"
0x007fffffe0d0 | +0x0020: 0x007fffffe000 → 0x007ffff7fad8
000
0x007fffffe0d8 | +0x0028: 0x005555555551fd → <_libc_csu_in
0x007fffffe0e0 | +0x0030: 0x007ffff7fb62e8 → 0x00000000000000
0x007fffffe0e8 | +0x0038: 0x005555555551b0 → <_libc_csu_in
```

```
gef> pattern search $rsp
[+] Searching for '$rsp'
[+] Found at offset 0 (little-endian search) likely
[+] Found at offset 0 (big-endian search)
```

```
gef> pattern search 0x007fffffe0b8
[+] Searching for '0x007fffffe0b8'
[+] Found at offset 8 (little-endian search) likely
[+] Found at offset 1 (big-endian search)
```

Các câu lệnh bổ sung

```
gef> set follow-fork-mode parent
gef> ni
[Detaching after fork from child process 323]
Thread con
0x000055555555517a in main ()
[ Legend: Modified register | Code | Heap | St
$rax : 0x143 Thread cha
```

```
gef> set follow-fork-mode child
gef> ni
[Attaching after process 325 fork to child process 331]
[New inferior 3 (process 331)]
[Detaching after fork from parent process 325]
Thread cha
[Inferior 2 (process 325) detached]
[Switching to process 331]
0x000055555555517a in main ()
[ Legend: Modified register | Code | Heap | Stack | Str
$rax : 0x0 Thread con
```

Khi làm việc với nhiều thread, ta có thể thiết lập GDB chạy theo thread cha hoặc thread con khi chương trình tạo thread mới (thông qua fork chẳng hạn).

Để theo thread cha, nhập:

set follow-fork-mode parent

Để đi theo thread con, nhập:

set follow-fork-mode child

Khi chạy fork

Giá trị trả về của thread con là 0

Giá trị trả về của thread cha là một số khác 0

Bạn có biết ?

"Debug động giúp ta kiểm tra
dữ liệu nhập vào trong thực
tế"

Johnathan Hữu Trí

Những điều
luôn đúng

Các câu lệnh bổ sung

```
(pyppwdbg) johnathanhuuttri@JohnathanHuuttri:~$ ps aux | grep r
root      1  0.0  0.0   1820   1072 ?        Ssl  19:09   0:00 /init
root      8  0.0  0.0   2112    348 ?        Ss   19:10   0:00 /init
root      9  0.0  0.0   2112    356 ?        S    19:10   0:00 /init
root     359  0.0  0.0   2080    400 ?        Ss   20:26   0:00 /init
root     360  0.0  0.0   2080    400 ?        S    20:26   0:00 /init
johnath+ 378  0.0  0.0   2492   576 pts/1    S+   20:26   0:00 ./r
johnath+ 385  0.0  0.0   8164   716 pts/0    S+   20:26   0:00 grep -r

(pyppwdbg) johnathanhuuttri@JohnathanHuuttri:~$ gdb -p 378
GNU gdb (Ubuntu 9.2-0ubuntu1~20.04.1) 9.2
Copyright (C) 2020 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
```

```
For help, type "help".
Type "apropos word" to search for commands related to "word".
GEF for linux ready, type 'gef' to start, 'gef config' to
90 commands loaded and 5 functions added for GDB 9.2 in
3.8
gef> attach 378
Attaching to process 378
Reading symbols from /home/johnathanhuuttri/r...
(No debugging symbols found in /home/johnathanhuuttri/r)
Reading symbols from /lib/x86_64-linux-gnu/libc.so.6...
```

Để debug với tiến trình đang chạy, ta cần phải lấy pid của tiến trình đó và nhập lệnh sau để debug động:

`gdb -p <pid>`

Ta cũng có thể chạy gdb trước và attach pid bằng lệnh sau:

`attach <pid>`



GDB

Cheat Sheet

Tra gg để có thêm thông tin chi tiết
Hoặc các bạn có thể dùng [file pdf](#) này



A graphic of a spiral-bound notebook with a white page, a red cover, and a green background. The page has a spiral binding at the top. On the left side, there are two horizontal tabs, one yellow and one orange. In the center of the page, the number '02' is displayed in a large, bold, black font, surrounded by a light green circular arrow. Below the number, the word 'Pwntools' is written in a bold, red, sans-serif font. Underneath that, the text 'Framework của python' is written in a smaller, black, sans-serif font.

02

Pwntools

Framework của python

Hướng dẫn cài đặt

```
user2@ubuntu:~$ sudo apt install python3-pip
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  binutils binutils-common binutils-x86-64-linux-gnu
  g++-9 gcc gcc-9 libalgorithm-diff-perl libalgorithm
  libasan5 libatomic1 libbinutils libc-dev-bin libc6-
```

```
user2@ubuntu:~$ pip install pwntools
Collecting pwntools
  Downloading pwntools-4.8.0-py2.py3-none-any.whl (11.7 MB)
    | 11.7 MB 7.2 MB/s
Collecting pyelftools>=0.2.4
  Downloading pyelftools-0.29-py2.py3-none-any.whl (174 kB)
    | 174 kB 8.4 MB/s
Collecting mako>=1.0.0
  Downloading Mako-1.2.4-py3-none-any.whl (78 kB)
    | 78 kB 5.9 MB/s
```

Để cài Pwntools, ta cần phải cài python3 và pip3. Python3 được cài mặc định trên một số HĐH nên ta chỉ cần cài pip3 nữa thôi. Chạy lệnh sau để cài pip3:

```
sudo apt install
python3-pip
```

Sau khi cài xong pip3, ta nhập câu lệnh dưới để cài pwntools:

```
pip install pwntools
```

Hướng dẫn cài đặt

Để kiểm tra xem pwntools đã được cài hay chưa, ta thử import thư viện vào python:

```
user2@ubuntu:~$ python3
Python 3.8.10 (default, Jun 22 2022, 20:18:18)
[GCC 9.4.0] on linux
Type "help", "copyright", "credits" or "license()"
>>> from pwn import *
>>>
```

Các lệnh cơ bản

Để tương tác với file binary, ta có thể dùng lệnh sau:

```
p = process('<đường dẫn tới file>')
```

Để người dùng tương tác với chương trình, ta chạy lệnh sau:

```
p.interactive()
```



```
>>> from pwn import *
>>>
>>> p = process('./r')
[*] Starting local process './r'
[+] Starting local process './r': pid 482
>>>
>>> p.interactive()
[*] Switching to interactive mode
What is your name?
Johnathan Huu Tri
> Thanks for coming!
[*] Process './r' stopped with exit code 0 (pid 482)
[*] Got EOF while reading in interactive
[*] Got EOF while sending in interactive
>>> |
```

Các lệnh cơ bản

Để tương tác với file binary, ta có thể dùng lệnh sau:

```
p = process('<đường dẫn tới file>')
```

Để người dùng tương tác với chương trình, ta chạy lệnh sau:

```
p.interactive()
```

Các lệnh cơ bản

Để tương tác gián tiếp thông qua pwntool, ta có các lệnh sau đây. Về lệnh nhận dữ liệu từ chương trình tới người dùng:

```
p.recv()  
p.recv(<số byte muốn nhận>)  
p.recvline()  
p.recvuntil(<chữ muốn nhận>)
```

```
>>> p = process('./r')  
[x] Starting local process './r'  
[+] Starting local process './r': pid 488  
>>> p.recv()  
b'What is your name?\n'
```

```
>>> p = process('./r')  
[x] Starting local process './r'  
[+] Starting local process './r': pid 490  
>>> p.recv(7)  
b'What is'
```

```
>>> p = process('./r')  
[x] Starting local process './r'  
[+] Starting local process './r': pid 489  
>>> p.recvline()  
b'What is your name?\n'
```

```
>>> p = process('./r')  
[x] Starting local process './r'  
[+] Starting local process './r': pid 491  
>>> p.recvuntil(b'your')  
b'What is your'
```

Các lệnh cơ bản

Để gửi dữ liệu từ người dùng tới chương trình, ta có các lệnh sau:

```
>>> p = process('./r')
[x] Starting local process './r'
[+] Starting local process './r': pid 493
>>> p.send(b'ahihi')
```

p.send(<dữ liệu>)

```
>>> p = process('./r')
[x] Starting local process './r'
[+] Starting local process './r': pid 495
>>> p.sendafter(b'name?', b'ahihi')
b'What is your name?'
```

p.sendafter(<dữ liệu nhận>, <dữ liệu gửi>)

```
>>> p = process('./r')
[x] Starting local process './r'
[+] Starting local process './r': pid 494
>>> p.sendline(b'ahihi')
```

p.sendline(<dữ liệu>)

```
>>> p = process('./r')
[x] Starting local process './r'
[+] Starting local process './r': pid 496
>>> p.sendlineafter(b'name?', b'ahihi')
b'What is your name?'
```

p.sendlineafter(<dữ liệu nhận>, <dữ liệu gửi>)

Bạn có biết ?
send(b'\n') giống với sendline()

Các lệnh cơ bản

Ngoài việc chạy file binary ra, ta còn có thể kết nối lên server bằng câu lệnh sau:

```
p = remote(<ip>, <port>)
```

```
>>> p = process('./ez-pwn-1')  
[x] Starting local process './ez-pwn-1'  
[+] Starting local process './ez-pwn-1': pid 514  
>>> p.recvline()  
b'Hi! would you like me to ls the current directory?\n'
```

```
>>> p = remote('chals.2022.squarectf.com', 4100)  
[x] Opening connection to chals.2022.squarectf.com on port 4100  
[x] Opening connection to chals.2022.squarectf.com on port 4100: Trying 3.220.119.234  
[+] Opening connection to chals.2022.squarectf.com on port 4100: Done  
>>> p.recvline()  
b'Hi! would you like me to ls the current directory?\n'
```

Các lệnh cơ bản

Vì dữ liệu được lưu trên stack với chuẩn Big Endian nên ta có sẵn công cụ chuyển từ số thành các byte Big Endian và từ byte về số như sau:

```
>>> p64(0xdeadbeefcafebabe)
b'\xbe\xba\xfe\xca\xef\xbe\xad\xde'
```

p64(<số nguyên dương>)

```
>>> hex( u64(b'\xbe\xba\xfe\xca\xef\xbe\xad\xde') )
'0xdeadbeefcafebabe'
>>> |
```

u64(<8 byte>)

Các lệnh cơ bản

```
nsert
C:\Windows\system32\wslex
$eflags: [ZERO carry PARITY adjust sign trap INTERRUPT direction overflow resume virtualx86 identification]
$cs: 0x33 $ss: 0x2b $ds: 0x00 $es: 0x00 $fs: 0x00 $gs: 0x00

stack
0x007ffc491d23a8 +0x0000: 0x0056084c800810 → <main+70> lea rax, [rbp-0x28] + $rsp
0x007ffc491d23b0 +0x0008: 0x007f5b956ca2e8 → 0x0000000000000000
0x007ffc491d23b8 +0x0010: 0x0056084c800870 → <_libc_csu_init+0> push r15 + $rsi
0x007ffc491d23c0 +0x0018: 0x00000000000736c (*1s"?)
0x007ffc491d23c8 +0x0020: 0x0056084c8006c0 → <_start+0> xor ebp, ebp
0x007ffc491d23d0 +0x0028: 0x007ffc491d24d0 → 0x0000000000000001
0x007ffc491d23d8 +0x0030: 0x4a98029c04b0cf00
0x007ffc491d23e0 +0x0038: 0x0000000000000000 + $rbp
code:x86:64

0x7f5b955e6fcc <read+12> test eax, eax
0x7f5b955e6fce <read+14> jne 0x7f5b955e6fe0 <__GI___libc_read+32>
0x7f5b955e6fd0 <read+16> syscall
0x7f5b955e6fd2 <read+18> cmp rax, 0xfffffffffffff000
0x7f5b955e6fd8 <read+24> ja 0x7f5b955e7030 <__GI___libc_read+112>
0x7f5b955e6fda <read+26> ret
0x7f5b955e6fdb <read+27> nop
0x7f5b955e6fe0 <read+32> sub rsp, 0x28
0x7f5b955e6fe4 <read+36> mov QWORD PTR [rsp+0x18], rdx

threads
[#0] Id 1, Name: "ez-pwn-1", stopped 0x7f5b955e6fd2 in __GI___libc_read (), reason: STOPPED
ED
>>>
>>> trace
[#0] 0x7f5b955e6fd2 → __GI___libc_read(fd=0x0, buf=0x7ffc491d23b8, nbytes=0x10)
[#1] 0x56084c800810 → main()
gef> |

>>>
>>>
>>>
>>> p = process('./ez-pwn-1')
[x] Starting local process './ez-pwn-1'
[*] Starting local process './ez-pwn-1': pid 585
>>> gdb.attach(p)
[*] running in new terminal: ['/usr/bin/gdb', '-q', './ez-pwn-1', '585']
[*] Waiting for debugger
[*] Waiting for debugger: Done
586
>>>
```

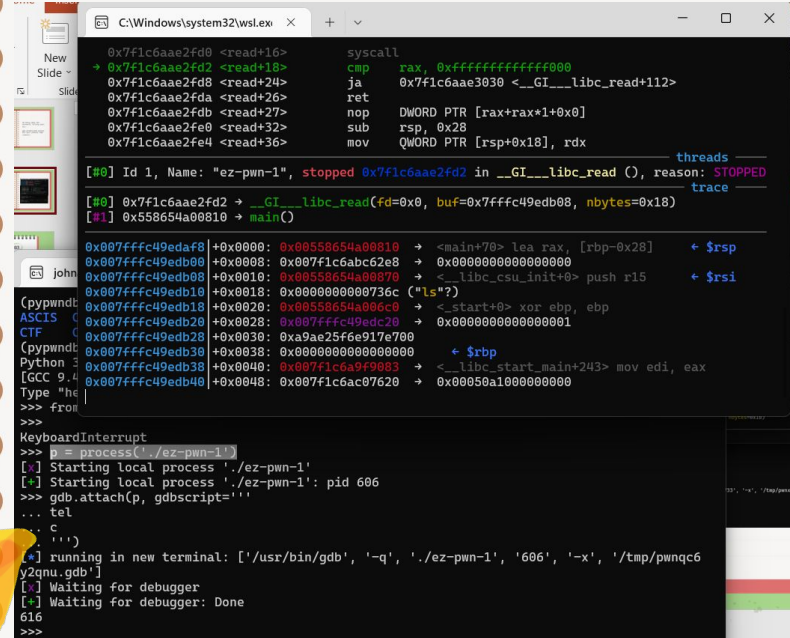
Để debug động với pwntools, ta dùng lệnh sau:

`gdb.attach(<cái output của lệnh process hoặc remote>)`

Các lệnh cơ bản

Để chạy các câu lệnh của gdb ngay khi attach, ta thêm tham số gdbscript:

```
gdb.attach(<object>,  
gdbscript=<command>)
```



```
C:\Windows\system32\wsl.exe x + v
New Slide
Slide
john
(pywndt)
ASCII
CTF
(pywndt)
Python
[GCC 9.4
Type "he
>>> from
>>>
KeyboardInterrupt
>>> p = process('./ez-pwn-1')
[*] Starting local process './ez-pwn-1'
[*] Starting local process './ez-pwn-1': pid 606
>>> gdb.attach(p, gdbscript='''
... tel
... c
... ''')
[*] running in new terminal: ['/usr/bin/gdb', '-q', './ez-pwn-1', '606', '-x', '/tmp/pwnqc6
y2anu.gdb']
[*] Waiting for debugger
[*] Waiting for debugger: Done
616
>>>
```

```
0x7f1c6aae2fd0 <read+16> syscall
+ 0x7f1c6aae2fd2 <read+18> cmp rax, 0xfffffffffffffff00
0x7f1c6aae2fd8 <read+24> ja 0x7f1c6aae3030 <_GI___libc_read+112>
0x7f1c6aae2fda <read+26> ret
0x7f1c6aae2fdb <read+27> nop DWORD PTR [rax+rax+1+0x0]
0x7f1c6aae2fe0 <read+32> sub rsp, 0x28
0x7f1c6aae2fe4 <read+36> mov QWORD PTR [rsp+0x18], rdx

[Id 1, Name: "ez-pwn-1", stopped 0x7f1c6aae2fd2 in __GI___libc_read (), reason: STOPPED]
[0] 0x7f1c6aae2fd2 -> __GI___libc_read(fd=0x0, buf=0x7fffc49edb08, nbytes=0x18)
[1] 0x558654a00810 -> main()

0x007fffc49edaf8 +0x0000: 0x00558654a00810 -> <main+70> lea rax, [rbp-0x28] + $rsp
0x007fffc49edb08 +0x0008: 0x007f1c6abc62e8 -> 0x0000000000000000
0x007fffc49edb08 +0x0010: 0x00558654a00870 -> <_libc_csu_init+0> push r15 + $rsi
0x007fffc49edb18 +0x0018: 0x000000000000736c ("ls??)
0x007fffc49edb18 +0x0020: 0x00558654a008c0 -> <_start+0> xor ebp, ebp
0x007fffc49edb20 +0x0028: 0x007fffc49edb20 -> 0x0000000000000001
0x007fffc49edb20 +0x0030: 0xa9ae25f6e017e700
0x007fffc49edb30 +0x0038: 0x0000000000000000 + $rbp
0x007fffc49edb30 +0x0040: 0x007f1c6a3f9083 -> <_libc_start_main+243> mov edi, eax
0x007fffc49edb40 +0x0048: 0x007f1c6ac07620 -> 0x000050a100000000
```



03

IDA / Ghidra

Dịch ngược chương trình

Hướng dẫn cài đặt IDA



- Ưu: giao diện dễ nhìn
- Nhược: chỉ decompile được file 64 bit

Xem tới cuối sẽ có điều bí mật :>

Các bạn tải IDA Free từ trang chủ (click vào ảnh bên dưới để đi tới trang chủ):

Download your IDA Free

The freeware version of IDA v8.1 comes with the following limitations:

- no commercial use is allowed
- cloud-based decompiler lacks certain advanced commands
- lacks support for many processors, file formats, etc...
- comes without technical support

SHA1 checksums:

 IDA Freeware for Windows (90MB)

 IDA Freeware for Linux (76MB)

 IDA Freeware for Mac (68MB)

 IDA Freeware for Mac ARM (70MB)

Nếu các bạn xài Windows thì tải bản dành cho Windows.

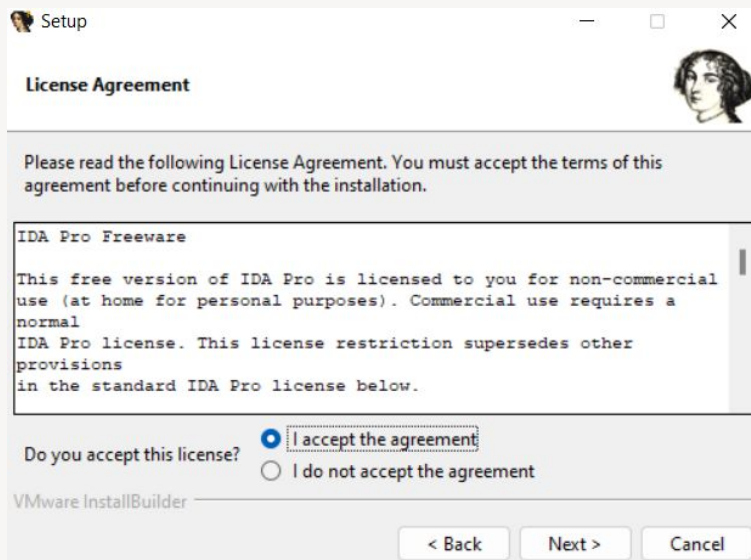
Nếu xài Ubuntu, Kali,... thì tải bản dành cho Linux.

Hướng dẫn cài đặt IDA

Để cài cho Windows, các bạn chạy file đã tải và bấm Next:

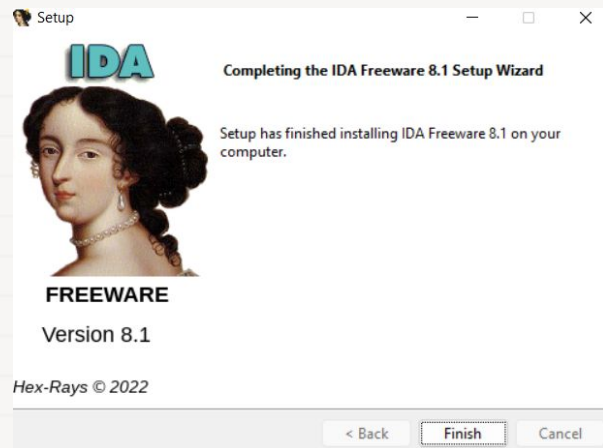
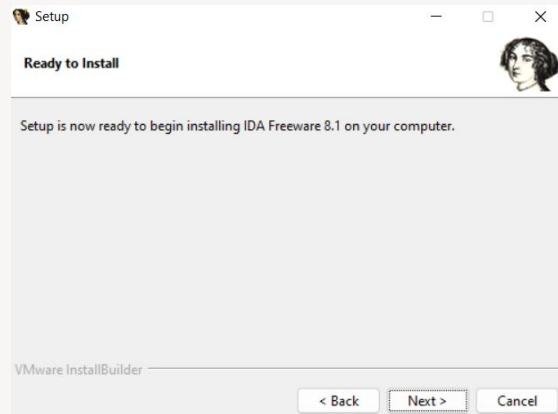
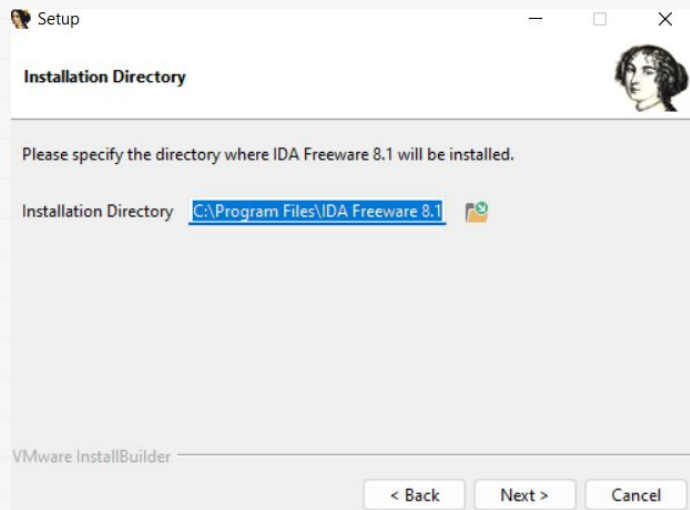


Kế đến tick vào "I accept the agreement" và chọn Next:



Hướng dẫn cài đặt IDA

Sau đó bấm Next đến hết
và bấm Finish



Hướng dẫn cài đặt IDA

Để cài cho Linux, các bạn thiết lập quyền thực thi cho file và chạy file như sau:

```
chmod +x <file IDA>
./<file IDA>
```

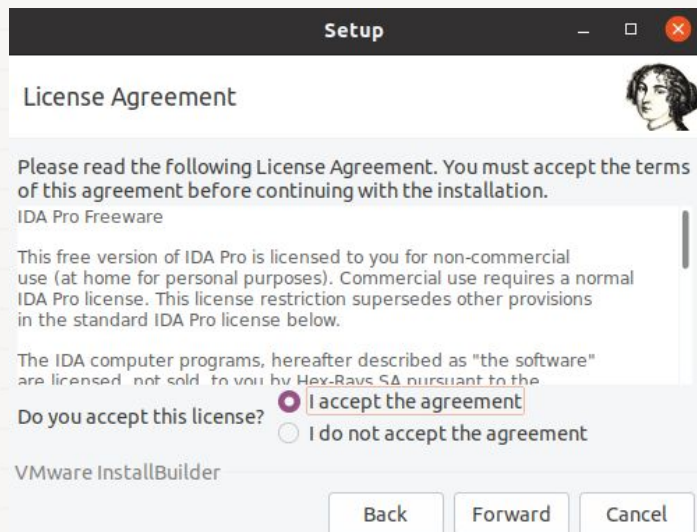
```
user2@ubuntu:~$ ls
Desktop Documents Downloads idafree81_linux.run
user2@ubuntu:~$ chmod +x idafree81_linux.run
user2@ubuntu:~$ ./idafree81_linux.run
```

Nó sẽ hiện lên một bảng setup mới, lúc này ta chọn Forward

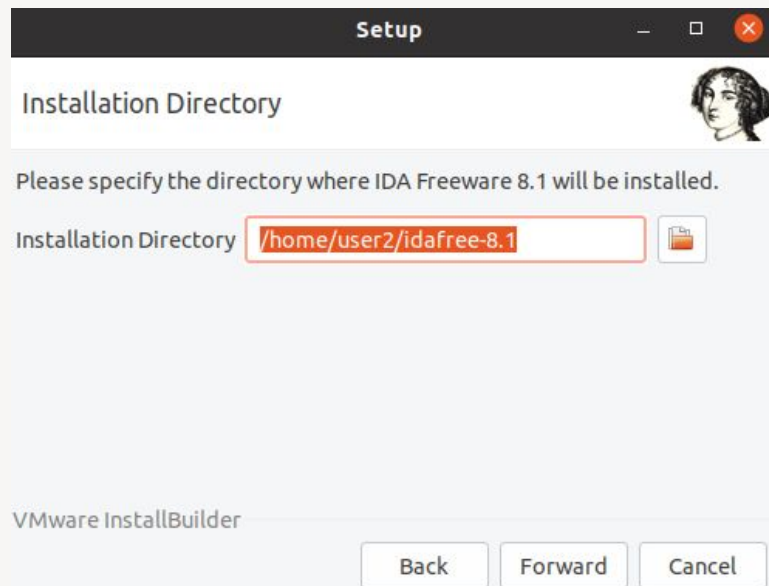


Hướng dẫn cài đặt IDA

Chọn “I accept the agreement” và chọn Forward

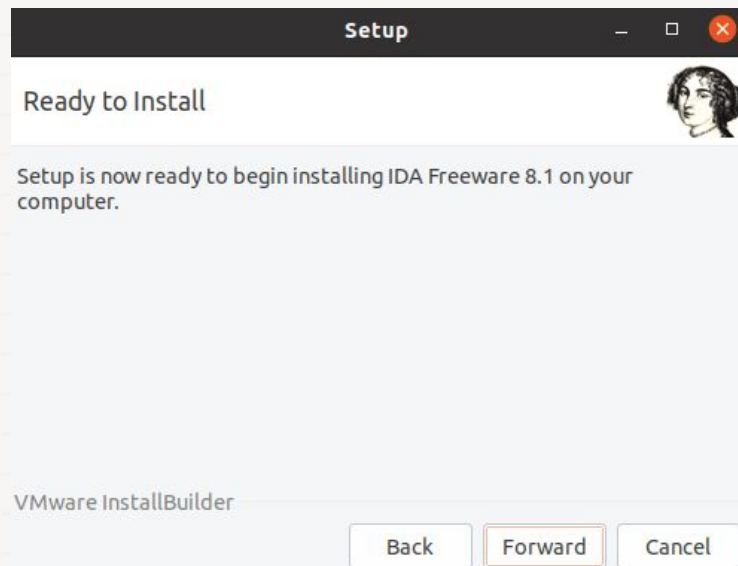


Chọn Forward



Hướng dẫn cài đặt IDA

Chọn Forward



Cuối cùng chọn Finish



Hướng dẫn cài đặt IDA

Đặc biệt, vì là KCSC member nên mình sẽ gửi tặng các bạn bản IDA 7.7 Pro Full Crack mình chôm được =))))

- Ưu: tốc độ decompile nhanh hơn hẳn bản Free, decompile được file 32 bit
- Nhược: chỉ xài được trên windows:>

Click vào hình bên phải để tới link tải

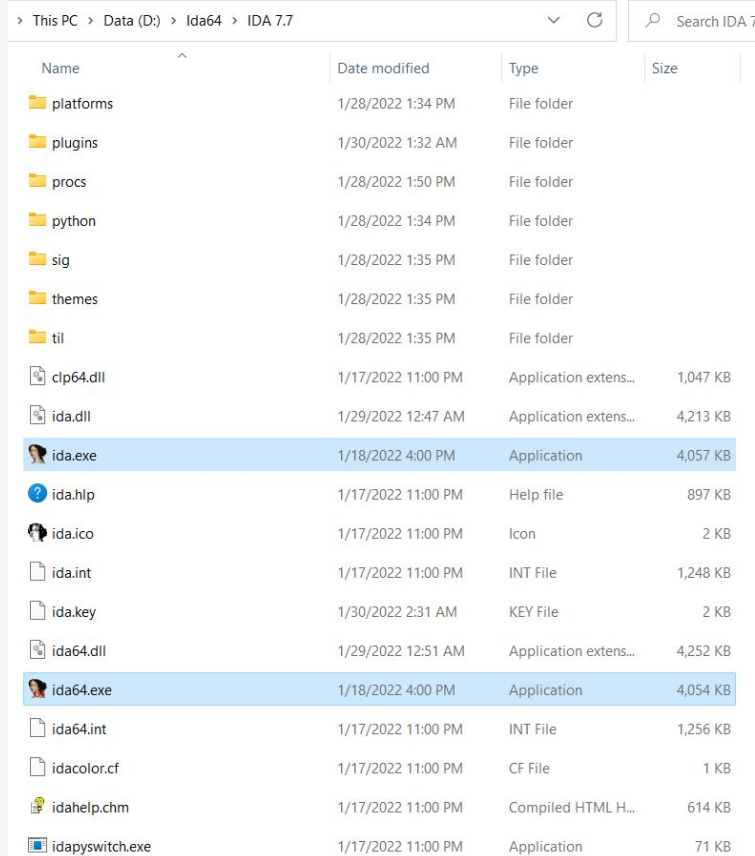


This PC > Data (D:) > Ida64 > IDA 7.7				Search IDA 7
Name	Date modified	Type	Size	
platforms	1/28/2022 1:34 PM	File folder		
plugins	1/30/2022 1:32 AM	File folder		
procs	1/28/2022 1:50 PM	File folder		
python	1/28/2022 1:34 PM	File folder		
sig	1/28/2022 1:35 PM	File folder		
themes	1/28/2022 1:35 PM	File folder		
til	1/28/2022 1:35 PM	File folder		
clp64.dll	1/17/2022 11:00 PM	Application extens...	1,047 KB	
ida.dll	1/29/2022 12:47 AM	Application extens...	4,213 KB	
ida.exe	1/18/2022 4:00 PM	Application	4,057 KB	
ida.hlp	1/17/2022 11:00 PM	Help file	897 KB	
ida.ico	1/17/2022 11:00 PM	Icon	2 KB	
ida.int	1/17/2022 11:00 PM	INT File	1,248 KB	
ida.key	1/30/2022 2:31 AM	KEY File	2 KB	
ida64.dll	1/29/2022 12:51 AM	Application extens...	4,252 KB	
ida64.exe	1/18/2022 4:00 PM	Application	4,054 KB	
ida64.int	1/17/2022 11:00 PM	INT File	1,256 KB	
idacolor.cf	1/17/2022 11:00 PM	CF File	1 KB	
idahelp.chm	1/17/2022 11:00 PM	Compiled HTML H...	614 KB	
idapyswitch.exe	1/17/2022 11:00 PM	Application	71 KB	

Hướng dẫn cài đặt IDA

Khi đã tải về, các bạn giải nén ra. Sẽ có 1 thư mục tên IDA 7.7, các bạn đi vào thư mục đó.

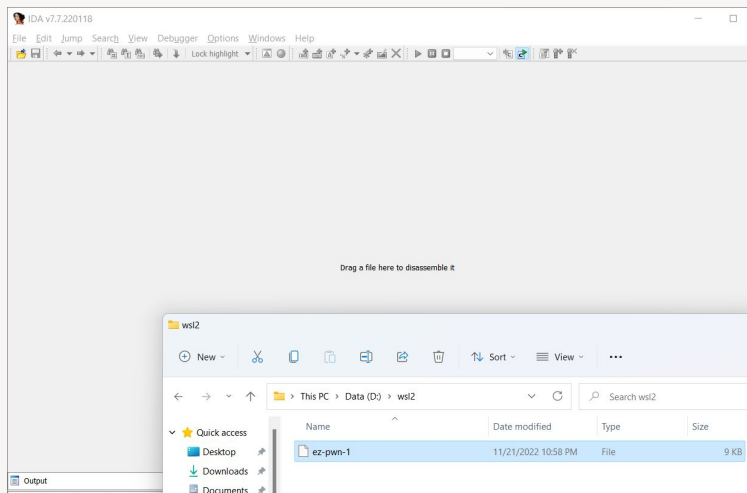
Nếu các bạn muốn decompile file 64bit thì các bạn chạy ida64.exe (file 32bit thì chạy ida.exe) và kéo thả file binary vào IDA tương ứng.



> This PC > Data (D:) > Ida64 > IDA 7.7

Name	Date modified	Type	Size
platforms	1/28/2022 1:34 PM	File folder	
plugins	1/30/2022 1:32 AM	File folder	
procs	1/28/2022 1:50 PM	File folder	
python	1/28/2022 1:34 PM	File folder	
sig	1/28/2022 1:35 PM	File folder	
themes	1/28/2022 1:35 PM	File folder	
til	1/28/2022 1:35 PM	File folder	
clp64.dll	1/17/2022 11:00 PM	Application extens...	1,047 KB
ida.dll	1/29/2022 12:47 AM	Application extens...	4,213 KB
ida.exe	1/18/2022 4:00 PM	Application	4,057 KB
ida.hlp	1/17/2022 11:00 PM	Help file	897 KB
ida.ico	1/17/2022 11:00 PM	Icon	2 KB
ida.int	1/17/2022 11:00 PM	INT File	1,248 KB
ida.key	1/30/2022 2:31 AM	KEY File	2 KB
ida64.dll	1/29/2022 12:51 AM	Application extens...	4,252 KB
ida64.exe	1/18/2022 4:00 PM	Application	4,054 KB
ida64.int	1/17/2022 11:00 PM	INT File	1,256 KB
idacolor.cf	1/17/2022 11:00 PM	CF File	1 KB
idahelp.chm	1/17/2022 11:00 PM	Compiled HTML H...	614 KB
idapyswitch.exe	1/17/2022 11:00 PM	Application	71 KB

Kế đến, ta kéo thả file binary vào IDA đã mở:



Hướng dẫn sử dụng IDA

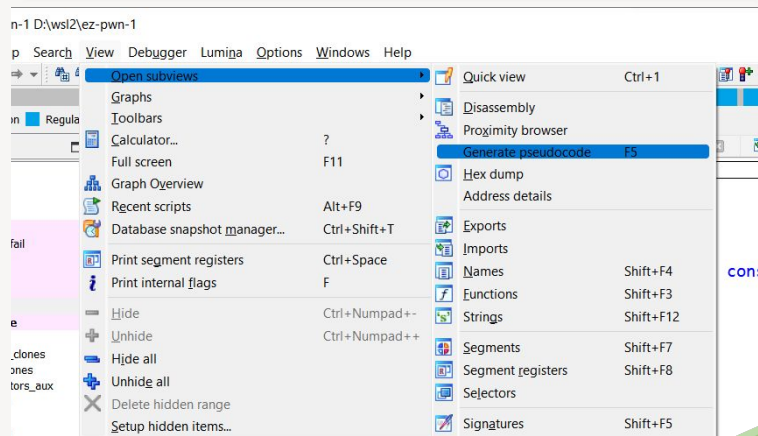
Giả sử ta muốn decompile 1 file 64bit, chạy ida64.exe trước:

ida.int	9/21/2022 12:36 PM	INT File	1,248 KB
ida.key	9/21/2022 12:36 PM	KEY File	2 KB
ida64.dll	9/21/2022 12:36 PM	Application extens...	4,252 KB
ida64.exe	9/21/2022 12:36 PM	Application	4,054 KB
ida64.int	9/21/2022 12:36 PM	INT File	1,256 KB
idacolor.cf	9/21/2022 12:36 PM	CF File	1 KB
idahelp.chm	9/21/2022 12:36 PM	Compiled HTML H...	614 KB

Để decompile file, ta chọn như sau:

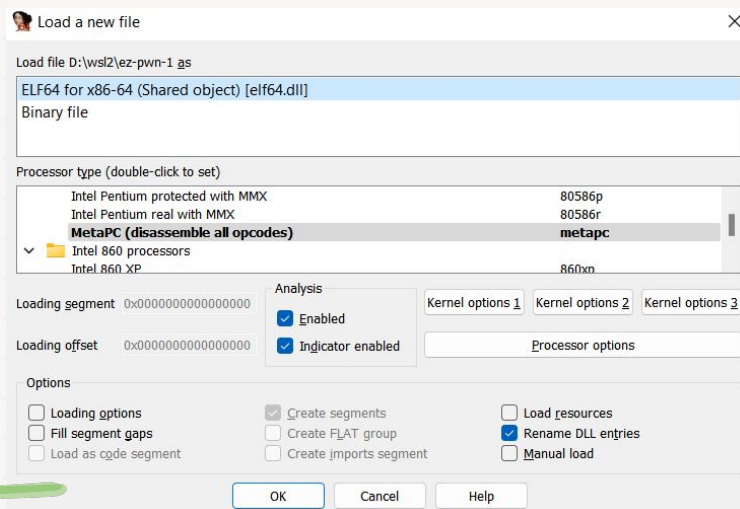
View -> Open Subviews ->
Generate pseudocode

Ta cũng có thể bấm phím F5
hoặc TAB cho nhanh

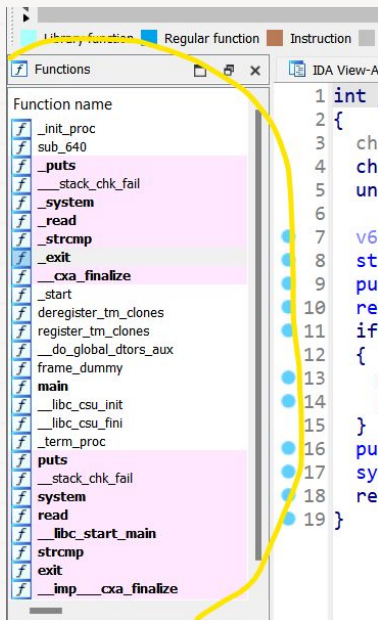


Hướng dẫn sử dụng IDA

Chương trình sẽ hiện popup như bên dưới, ta chỉ việc bấm OK là được:



Mặc định, nó sẽ hiện cột các functions ở bên trái của IDA. Nếu là file không bị strip, ta có thể xem tên của các function ở đây:



Hướng dẫn sử dụng IDA

Đây là giao diện sau khi decompile, nhìn y chang code c:

```
1 int __cdecl main(int argc, const char **argv, const char **envp)
2 {
3     char buf[8]; // [rsp+8h] [rbp-28h] BYREF
4     char command[24]; // [rsp+10h] [rbp-20h] BYREF
5     unsigned __int64 v6; // [rsp+28h] [rbp-8h]
6
7     v6 = __readfsqword(0x28u);
8     strcpy(command, "ls");
9     puts("Hi! would you like me to ls the current directory?");
10    read(0, buf, 0x18uLL);
11    if ( !strcmp(buf, "no\n") )
12    {
13        puts("Oh, ok :(");
14        exit(0);
15    }
16    puts("Ok, here ya go!\n");
17    system(command);
18    return 0;
19 }
```



04



checksec

Kiểm tra các chức năng
bảo vệ của file

Hướng dẫn cài đặt

Để cài checksec, ta chạy lệnh sau:

```
sudo apt install checksec
```

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ sudo apt install checksec
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer re
bubblewrap gnome-desktop3-data libcue2 libdbusmenu-glib4 libdee-1.0-4
libgnome-autoar-0-0 libgnome-desktop-3-19 libgsf-1-114 libgsf-1-common
libpoppler-glib8 libpoppler97 libtotem-plparser-common libtotem-plpars
libtracker-miner-2.0-0 libtracker-spargl-2.0-0 libunity-protocol-privat
libupower-glib3 nautilus-data poppler-data tracker tracker-extract tra
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
checksec
```

Hướng dẫn sử dụng

Để kiểm tra các lớp bảo mật của một file, nhập:

```
checksec -file=<đường dẫn>
```

Có 4 yếu tố chính để ta kiểm tra:

- RELRO
- STACK CANARY
- NX
- PIE

```
johnathanhuutri@JohnathanHuuTri:~$ checksec --file=e3-pwn-1
RELRO          STACK CANARY    NX             PIE
Full RELRO     Canary found    NX enabled     PIE enabled
```



05

rapper

Tìm kiếm những đoạn nhỏ
của chương trình

Hướng dẫn cài đặt

ropper là công cụ của python nên việc cài đặt sẽ cần pip3. Để cài pip3, nhập:

```
sudo apt install python3-pip
```

```
johnathanhuutri@JohnathanHuuTri:~$ sudo apt install python3-pip
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer
required:
  libafflib0v5 libdate-manip-perl libewf2 libtsk13
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  python3-pip
0 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 0 B/231 kB of archives.
After this operation, 1050 kB of additional disk space will be used.
Selecting previously unselected package python3-pip.
(Reading database ... 91373 files and directories currently installed.)
Preparing to unpack .../python3-pip_20.0.2-5ubuntu1.6_all.deb ...
Unpacking python3-pip (20.0.2-5ubuntu1.6) ...
Setting up python3-pip (20.0.2-5ubuntu1.6) ...
Processing triggers for man-db (2.9.1-1) ...
```

Sau đó ta cài các thư viện cần thiết cho ropper:

```
sudo pip3 install capstone
filebytes ropper
```

```
johnathanhuutri@JohnathanHuuTri:~$ sudo pip3 install capstone filebytes ropper
Collecting capstone
  Using cached capstone-4.0.2-py3.py3-none-manylinux1_x86_64.whl (2.1 MB)
Collecting filebytes
  Downloading filebytes-0.10.2.tar.gz (20 kB)
Collecting ropper
  Downloading ropper-1.13.8.tar.gz (71 kB)
Building wheels for collected packages: filebytes, ropper
  Building wheel for filebytes (setup.py) ... done
  Created wheel for filebytes: filename=filebytes-0.10.2-py3-none-any.whl size=27853 sha256=0733a98a233312b50f4524366fed23d49fa82c82201cb9a9db420ee1c220b677
  Stored in directory: /root/.cache/pip/wheels/ab/48/4c/b1c28c67f67b1062c290e51d9a1a
e5224c1dc145da55dba5c8
  Building wheel for ropper (setup.py) ... done
  Created wheel for ropper: filename=ropper-1.13.8-py3-none-any.whl size=99938 sha256=b557fb47fc5da2f78409392243d89a67cc95a63296bb13327938484ca322d8ca
  Stored in directory: /root/.cache/pip/wheels/a6/95/b8/2c85b1feaba535a9f36c62e2a47c
d8b44bc6b1b025da335357
Successfully built filebytes ropper
Installing collected packages: capstone, filebytes, ropper
Successfully installed capstone-4.0.2 filebytes-0.10.2 ropper-1.13.8
```

Để tìm gadget có chứa chuỗi
chỉ định, nhập:

```
ropper --file=<đường dẫn>  
--search=<chuỗi>
```

```
johnathanhuutri@JohnathanHuuTri:~$ ropper --file ez-pwn-1 --search="pop"  
[INFO] Load gadgets from cache  
[LOAD] loading... 100%  
[LOAD] removing double gadgets... 100%  
[INFO] Searching for gadgets: pop
```

```
[INFO] File: ez-pwn-1  
0x00000000000008cc: pop r12; pop r13; pop r14; pop r15; ret;  
0x00000000000008ce: pop r13; pop r14; pop r15; ret;  
0x00000000000008d0: pop r14; pop r15; ret;  
0x00000000000008d2: pop r15; ret;  
0x0000000000000713: pop rbp; jmp rax;  
0x00000000000008cb: pop rbp; pop r12; pop r13; pop r14; pop r15; ret;  
0x00000000000008cf: pop rbp; pop r14; pop r15; ret;  
0x0000000000000720: pop rbp; ret;  
0x00000000000008d3: pop rdi; ret;  
0x00000000000008d1: pop rsi; pop r15; ret;  
0x00000000000008cd: pop rsp; pop r13; pop r14; pop r15; ret;
```

```
johnathanhuutri@JohnathanHuuTri:~$ ropper --file ez-pwn-1 --search="pop  
rdi"  
[INFO] Load gadgets from cache  
[LOAD] loading... 100%  
[LOAD] removing double gadgets... 100%  
[INFO] Searching for gadgets: pop rdi  
  
[INFO] File: ez-pwn-1  
0x00000000000008d3: pop rdi; ret;
```

Hướng dẫn sử dụng

Để tìm tất cả gadget, nhập:

```
ropper --file=<đường dẫn>
```

```
johnathanhuutri@JohnathanHuuTri:~$ ropper --file ez-pwn-1  
[INFO] Load gadgets from cache  
[LOAD] loading... 100%  
[LOAD] removing double gadgets... 100%  
  
Gadgets  
=====
```

```
0x00000000000007b7: add bl, dh; ret;  
0x0000000000000632: add byte ptr [rax - 0x7b], cl; sal byte ptr [rdx + r  
ax - 1], 0xd0; add rsp, 8; ret;  
0x00000000000007b5: add byte ptr [rax], al; add bl, dh; ret;  
0x00000000000008db: add byte ptr [rax], al; add byte ptr [rax], al; add  
bl, dh; ret;  
0x000000000000071c: add byte ptr [rax], al; add byte ptr [rax], al; pop  
rbp; ret;  
0x0000000000000865: add byte ptr [rax], al; je 0x86e; call 0x660; leave;  
ret;
```



06

pwninit

Patch libc vào binary



Hướng dẫn cài đặt

pwninit là một file binary nên ta chỉ việc tải về từ trang chủ (click vào ảnh để đi tới đường link tải):

3.2.0 Latest Compare

io12 released this Feb 16 3.2.0 dc024f3

Release 3.2.0

▼ Assets 3

pwninit	6.14 MB	Feb 16
Source code (zip)		Feb 16
Source code (tar.gz)		Feb 16

Hướng dẫn cài đặt

Bạn có biết ?

Ta cũng có thể dùng patchelf để patch binary với libc bằng tay đấy

Trước khi dùng, ta phải cài thêm patchelf để pwninit có thể chạy được. Nhập câu lệnh sau để cài patchelf:

```
sudo apt install patchelf
```

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ sudo apt install patchelf
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer re
bubblewrap gnome-desktop3-data libcue2 libdbusmenu-glib4 libdee-1.0-4
libgnome-autoar-0-0 libgnome-desktop-3-19 libgsf-1-114 libgsf-1-common
libpoppler-glib8 libpoppler97 libtotem-plparser-common libtotem-plpars
libtracker-miner-2.0-0 libtracker-sparql-2.0-0 libunity-protocol-privat
libupower-glib3 nautilus-data poppler-data tracker tracker-extract tra
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
patchelf
```

Hướng dẫn cài đặt

Để tiện cho việc patch file, ta sẽ đưa phần mềm đó vào thư mục global để khi ta cần patch, ta chỉ việc gõ lệnh:

pwninit

Để làm điều đó, ta có 2 cách:

- Tải trực tiếp vào thư mục `"/usr/bin"`
- Đưa file pwninit vào thư mục `"/usr/bin"`

Cuối cùng ta set quyền thực thi cho file pwninit:

`sudo chmod +x /usr/bin/pwninit`

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ sudo wget https://github.com/io12/pwninit/releases/download/3.2.0/pwninit
--2022-11-19 23:00:17-- https://github.com/io12/pwninit/releases/download/3.2.0/pwninit
Resolving github.com (github.com)... 20.205.243.166
Connecting to github.com (github.com)|20.205.243.166|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://objects.githubusercontent.com/github-production-release-asset-2e65be/219250679/9d3150e4-0070-4547-be93-d94d7bf097c2?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAIWNJYAX4CSVEH53A%2F20221119%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20221119T155933Z&X-Amz-Expires=300&X-Amz-Signature=03da89c74c08ab8799dc31b3a232f1e2aff73ea6ae4a46fa542b244fa14377d1&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=219250679&response-content-disposition=attachment%3B%20filename%3Dpwninit&response-content-type=application%2Foctet-stream [following]
--2022-11-19 23:00:17-- https://objects.githubusercontent.com/github-production-release-asset-2e65be/219250679/9d3150e4-0070-4547-be93-d94d7bf097c2?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAIWNJYAX4CSVEH53A%2F20221119%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20221119T155933Z&X-Amz-Expires=300&X-Amz-Signature=03da89c74c08ab8799dc31b3a232f1e2aff73ea6ae4a46fa542b244fa14377d1&X-Amz-SignedHeaders=host&actor_id=0&key_id=0&repo_id=219250679&response-content-disposition=attachment%3B%20filename%3Dpwninit&response-content-type=application%2Foctet-stream
Resolving objects.githubusercontent.com (objects.githubusercontent.com)... 185.199.110.133, 185.199.108.133, 185.199.109.133, ...
Connecting to objects.githubusercontent.com (objects.githubusercontent.com)...
```

```
johnathanhuutri@JohnathanHuuTri:~$ ls -al | grep pwninit
-rw-r--r-- 1 johnathanhuutri johnathanhuutri 6439432 Feb 16 2022 pwninit
johnathanhuutri@JohnathanHuuTri:~$ sudo mv pwninit /usr/bin
[sudo] password for johnathanhuutri:
johnathanhuutri@JohnathanHuuTri:~$ ls -al /usr/bin/pwninit
-rw-r--r-- 1 johnathanhuutri johnathanhuutri 6439432 Feb 16 2022 /usr/bin/pwninit
johnathanhuutri@JohnathanHuuTri:~$
```

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ sudo chmod +x /usr/bin/pwninit
[sudo] password for johnathanhuutri:
```

Hướng dẫn sử dụng

Ta di chuyển vào folder có chứa libc và binary (libc và binary bắt buộc phải để cùng 1 thư mục):

```
johnathanhuutri@JohnathanHuuTri:~/CTF/SquareCTF202/3itemmenu$ ls  
libc.so.6  three_item_menu
```

Kế đến, ta chỉ việc chạy lệnh “pwninit”:

```
johnathanhuutri@JohnathanHuuTri:~/CTF/SquareCTF202/3itemmenu$ pwninit  
bin: ./three_item_menu  
libc: ./libc.so.6  
  
setting ./three_item_menu executable  
fetching linker  
https://launchpad.net/ubuntu/+archive/primary/+files//libc6\_2.27-3ubuntu1.6\_amd64.deb  
setting ./ld-2.27.so executable  
copying ./three_item_menu to ./three_item_menu_patched  
running patchelf on ./three_item_menu_patched  
writing solve.py stub  
johnathanhuutri@JohnathanHuuTri:~/CTF/SquareCTF202/3itemmenu$ ls  
ld-2.27.so  libc.so.6  solve.py  three_item_menu  three_item_menu_patched
```





07

file

Kiểm tra định dạng của
file

Hướng dẫn cài đặt

Lệnh file là package của linux nên ta sẽ cài như sau:

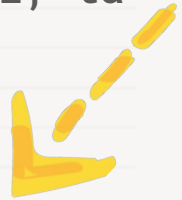
`sudo apt install file`

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ sudo apt install file
[sudo] password for johnathanhuutri:
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer
needed:
  libaflib0v5 libdate-manip-perl libewf2 libtsk13
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  file
0 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 23.3 kB of archives.
After this operation, 88.1 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu focal/main amd64 file amd64 1
[23.3 kB]
Fetched 23.3 kB in 1s (24.7 kB/s)
Selecting previously unselected package file.
(Reading database ... 91566 files and directories currently installed)
Preparing to unpack .../file_1%3a5.38-4_amd64.deb ...
Unpacking file (1:5.38-4) ...
Setting up file (1:5.38-4) ...
Processing triggers for man-db (2.9.1-1) ...
```

Hướng dẫn sử dụng

Để xác định 1 file (không có đuôi mở rộng) là file gì, ta chỉ việc nhập:

`file <tên file>`



```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ file ez-pwn-1
ez-pwn-1: ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, for GNU/Linux 3.2.0, BuildID[sha1]=26217945613bd2e86e73d01ae50a82c592549ccc, not stripped
```

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ file image
image: PNG image data, 691 x 462, 8-bit/color RGBA, non-interlaced
```

```
(pypwndbg) johnathanhuutri@JohnathanHuuTri:~$ file another_image
another_image: JPEG image data, JFIF standard 1.01, aspect ratio, density 1x1, segment length 16, comment: "Compressed by jpeg-recompress", progressive, precision 8, 691x462, components 3
```



08

man page

Kiểm tra định dạng của
file

Hướng dẫn cài đặt

Man page là công cụ có thể tìm thấy trên linux và google nhưng để thuận tiện, ta có thể cài trên linux nếu chưa có. Để cài đặt, gõ:

```
sudo apt install man-db
```

```
user2@ubuntu:~$ sudo apt install man-db
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer required:
  docbook-xml libglu1-mesa libyelp0 sgml-base sgml-data x11-session-utils xbitmaps xinit
  xml-core yelp-xsl
Use 'sudo apt autoremove' to remove them.
Suggested packages:
  groff
The following NEW packages will be installed:
  man-db
```

Hướng dẫn sử dụng

Để tìm kiếm cách sử dụng cho 1 hàm, ta nhập:

man <tên hàm>

VD: “man 2 write” (vì “man write” sẽ ra hàm khác)
“man fgets” (hoặc “man 3 fgets”)

```
user2@ubuntu:~$ man 2 write
```

```
WRITE(2) Linux Programmer's Manual WRITE(2)
NAME
  write - write to a file descriptor

SYNOPSIS
  #include <unistd.h>

  ssize_t write(int fd, const void *buf, size_t count);

DESCRIPTION
  write() writes up to count bytes from the buffer starting at buf to the file referred to by the file descriptor fd.

  The number of bytes written may be less than count if, for example, there is insufficient space on the underlying physical medium, or the RLIMIT_FSIZE resource limit is encountered (see setrlimit(2)), or the call was interrupted by a signal handler after having written less than count bytes. (See also pipe(7).)
```

```
user2@ubuntu:~$ man fgets
```

```
user2@ubuntu:~$ man 3 fgets
```

```
FGETC(3) Linux Programmer's Manual FGETC(3)
NAME
  fgets, fgets, getc, getchar, ungetc - input of characters and strings

SYNOPSIS
  #include <stdio.h>

  int fgetc(FILE *stream);

  char *fgets(char *s, int size, FILE *stream);

  int getc(FILE *stream);

  int getchar(void);

  int ungetc(int c, FILE *stream);
```